Chapter 4 / Capítulo 4

Self-assessment / Autoevaluación

Source / Fuente: CISA Official Review Manual, ISACA. Preguntas y clave proporcionadas por el usuario. Traducción no oficial. Se incluye el inglés con correcciones de errores de reconocimiento de texto y su traducción al español. Los guiones son explicaciones propias para responder oralmente.

Answer key / Clave: 1-C · 2-D · 3-A · 4-A · 5-A · 6-A · 7-C · 8-A · 9-A · 10-D

Question 1 / Pregunta 1

English: Which one of the following provides the BEST method for determining the level of performance provided by similar information processing facility (IPF) environments?

A. User satisfaction
B. Goal accomplishment
C. Benchmarking
D. Capacity and growth planning

Español: ¿Cuál de los siguientes proporciona el MEJOR método para determinar el nivel de rendimiento ofrecido por entornos similares de instalaciones de procesamiento de información (IPF)?

A. Satisfacción de los usuarios.
B. Cumplimiento de objetivos.
C. Comparación de referencia (benchmarking).
D. Planificación de capacidad y crecimiento.

Correct answer / Respuesta correcta: C

Explanation of every option / Justificación de cada alternativa

A. Incorrect / Incorrecta

English: User satisfaction is the measure to ensure that an effective information processing operation meets user requirements.

Español: La satisfacción de los usuarios es la medida que permite comprobar que una operación eficaz de procesamiento de información cumple sus requisitos.

B. Incorrect / Incorrecta

English: Goal accomplishment evaluates the effectiveness involved in comparing performance with predefined goals.

Español: El cumplimiento de objetivos evalúa la eficacia mediante la comparación del rendimiento con metas predefinidas.

C. Correct / Correcta

English: Benchmarking provides a means of determining the level of performance offered by similar information processing facility (IPF) environments.

Español: El benchmarking proporciona un medio para determinar el nivel de rendimiento ofrecido por entornos similares de instalaciones de procesamiento de información (IPF).

D. Incorrect / Incorrecta

English: Capacity and growth planning are essential due to the importance of IT in organizations and the constant technological change.

Español: La planificación de capacidad y crecimiento es esencial debido a la importancia de TI en las organizaciones y al cambio tecnológico constante.

Suggested speaking script / Guion sugerido

English: I would choose C because benchmarking compares our performance with similar facilities. User satisfaction or internal goals do not provide that external comparison.

Español: Elegiría la C porque el benchmarking compara nuestro rendimiento con instalaciones similares. La satisfacción del usuario o las metas internas no proporcionan esa comparación externa.

Question 2 / Pregunta 2

English: For mission critical systems with a low tolerance to interruption and a high cost of recovery, the information systems (IS) auditor, in principle, recommends the use of which of the following recovery options?

A. Mobile site
B. Warm site
C. Cold site
D. Hot site

Español: Para sistemas de misión crítica con baja tolerancia a las interrupciones y un alto costo de recuperación, ¿cuál de las siguientes opciones de recuperación recomienda, en principio, el auditor de sistemas de información (SI)?

A. Sitio móvil.
B. Sitio parcialmente equipado (warm site).
C. Sitio con infraestructura básica (cold site).
D. Sitio totalmente equipado y listo para operar (hot site).

Correct answer / Respuesta correcta: D

Explanation of every option / Justificación de cada alternativa

A. Incorrect / Incorrecta

English: Mobile sites are specially designed trailers that can be quickly transported to a business location or to an alternate site to provide a ready-conditioned information processing facility (IPF).

Español: Los sitios móviles son remolques especialmente diseñados que pueden transportarse rápidamente a una ubicación de la empresa o a un sitio alternativo para proporcionar una instalación de procesamiento de información (IPF) acondicionada y lista.

B. Incorrect / Incorrecta

English: Warm sites are partially configured, usually with network connections and selected peripheral equipment-such as disk drives and controllers - but without the main computer.

Español: Los warm sites están parcialmente configurados, normalmente con conexiones de red y determinados equipos periféricos, como unidades de disco y controladores, pero sin la computadora principal.

C. Incorrect / Incorrecta

English: Cold sites have only the basic environment to operate an IPF. Cold sites are ready to receive equipment but do not offer any components at the site before the need.

Español: Los cold sites solo cuentan con el entorno básico para operar una IPF. Están preparados para recibir equipos, pero no ofrecen componentes en el sitio antes de que surja la necesidad.

D. Correct / Correcta

English: Hot sites are fully configured and ready to operate within several hours or, in some cases, even minutes.

Español: Los hot sites están completamente configurados y preparados para operar en unas horas o, en algunos casos, incluso en minutos.

Suggested speaking script / Guion sugerido

English: I would choose D because a hot site is already equipped and configured. It supports fast recovery when the business cannot tolerate a long interruption.

Español: Elegiría la D porque un hot site ya está equipado y configurado. Permite recuperar la operación rápidamente cuando el negocio no tolera una interrupción prolongada.

Question 3 / Pregunta 3

English: Which of the following is the MOST effective method for an IS auditor to use in testing the program change management process?

A. Trace from system-generated information to the change management documentation

B. Examine change management documentation for evidence of accuracy

C. Trace from the change management documentation to a system-generated audit trail

D. Examine change management documentation for evidence of completeness

Español: ¿Cuál es el método MÁS eficaz que puede utilizar un auditor de SI para probar el proceso de gestión de cambios de programas?

A. Rastrear desde la información generada por el sistema hasta la documentación de gestión de cambios.

B. Examinar la documentación de gestión de cambios para comprobar su exactitud.

C. Rastrear desde la documentación de gestión de cambios hasta una pista de auditoría generada por el sistema.

D. Examinar la documentación de gestión de cambios para comprobar que esté completa.

Correct answer / Respuesta correcta: A

Explanation of every option / Justificación de cada alternativa

A. Correct / Correcta

English: When testing change management, the information systems (IS) auditor should start with system-generated information, containing the date and time a module was last updated, and trace from there to the documentation authorizing the change.

Español: Al probar la gestión de cambios, el auditor de SI debe comenzar con información generada por el sistema que contenga la fecha y hora de la última actualización de un módulo y, desde allí, rastrear hasta la documentación que autoriza el cambio.

B. Incorrect / Incorrecta

English: Focusing exclusively on the accuracy of the documentation examined does not ensure that all changes were, in fact, documented.

Español: Centrarse exclusivamente en la exactitud de la documentación examinada no garantiza que todos los cambios hayan sido realmente documentados.

C. Incorrect / Incorrecta

English: To trace in the opposite direction would run the risk of not detecting undocumented changes.

Español: Rastrear en la dirección opuesta implica el riesgo de no detectar cambios que no estén documentados.

D. Incorrect / Incorrecta

English: Focusing exclusively on the completeness of the documentation examined does not ensure that all changes were, in fact, documented.

Español: Centrarse exclusivamente en que la documentación examinada esté completa no garantiza que todos los cambios hayan sido realmente documentados.

Suggested speaking script / Guion sugerido

English: I would choose A because I would first identify the changes that actually occurred in the system, then check their authorization. Starting with documents could miss undocumented changes.

Español: Elegiría la A porque primero identificaría los cambios que realmente ocurrieron en el sistema y luego comprobaría su autorización. Si comienzo por los documentos, podría omitir cambios no documentados.

Question 4 / Pregunta 4

English: Which of the following would allow an enterprise to extend its intranet across the internet to its business partners?

A. Virtual private network (VPN)
B. Client-server
C. Dial-up access
D. Network service provider (NSP)

Español: ¿Cuál de las siguientes opciones permitiría a una empresa extender su intranet a través de Internet hasta sus socios comerciales?

A. Red privada virtual (VPN).
B. Cliente-servidor.
C. Acceso por conexión telefónica (dial-up).
D. Proveedor de servicios de red (NSP).

Correct answer / Respuesta correcta: A

Explanation of every option / Justificación de cada alternativa

A. Correct / Correcta

English: Virtual private network (VPN) technology allows external partners to securely participate in the extranet using public networks as a transport or shared private network. Because of low cost, using public networks (Internet) as a transport is the principal method. VPNs rely on tunneling/encapsulation techniques, which allow the Internet Protocol (IP) to carry a variety of different protocols (e.g., systems network architecture [SNA] and internetwork packet exchange [IPX]).

Español: La tecnología de red privada virtual (VPN) permite que los socios externos participen de forma segura en la extranet utilizando redes públicas como medio de transporte o una red privada compartida. Debido al bajo costo, el método principal consiste en utilizar redes públicas (Internet) como transporte. Las VPN se basan en técnicas de túneles y encapsulación que permiten al Protocolo de Internet (IP) transportar distintos protocolos, como la arquitectura de redes de sistemas (SNA) y el intercambio de paquetes entre redes (IPX).

B. Incorrect / Incorrecta

English: Client-server does not address extending the network to business partners (i.e., client-server refers to a group of computers within an organization connected by a communications network where the client is the requesting machine and the server is the supplying machine).

Español: La arquitectura cliente-servidor no aborda la extensión de la red a los socios comerciales. Se refiere a un grupo de computadoras dentro de una organización conectadas por una red de comunicaciones, donde el cliente es el equipo que solicita y el servidor el que proporciona el servicio.

C. Incorrect / Incorrecta

English: Although it may be technically possible for an enterprise to extend its intranet using dial-up access, it would not be practical or cost effective to do so.

Español: Aunque técnicamente una empresa podría extender su intranet mediante acceso telefónico, no sería práctico ni rentable hacerlo.

D. Incorrect / Incorrecta

English: A network service provider may provide services to a shared private network by providing Internet services, but it does not extend an organization's intranet.

Español: Un proveedor de servicios de red puede prestar servicios a una red privada compartida al proporcionar servicios de Internet, pero no extiende la intranet de una organización.

Suggested speaking script / Guion sugerido

English: I would choose A because a VPN provides a protected connection over the internet. This allows authorized business partners to connect securely to the organization’s network.

Español: Elegiría la A porque una VPN proporciona una conexión protegida a través de Internet. Así, los socios comerciales autorizados pueden conectarse de forma segura a la red de la organización.

Question 5 / Pregunta 5

English: The classification based on criticality of a software application as part of an IS business continuity plan is determined by the:

A. nature of the business and the value of the application to the business.
B. replacement cost of the application.
C. vendor support available for the application.
D. associated threats and vulnerabilities of the application.

Español: La clasificación de una aplicación de software según su criticidad, como parte de un plan de continuidad del negocio de SI, se determina por:

A. La naturaleza del negocio y el valor de la aplicación para el negocio.
B. El costo de reemplazo de la aplicación.
C. El soporte del proveedor disponible para la aplicación.
D. Las amenazas y vulnerabilidades asociadas a la aplicación.

Correct answer / Respuesta correcta: A

Explanation of every option / Justificación de cada alternativa

A. Correct / Correcta

English: The criticality classification is determined by the role of the application system in supporting the strategy of the organization.

Español: La clasificación de criticidad se determina por el papel del sistema de aplicación en el apoyo a la estrategia de la organización.

B. Incorrect / Incorrecta

English: The replacement cost of the application does not reflect the relative value of the application to the business.

Español: El costo de reemplazo de la aplicación no refleja su valor relativo para el negocio.

C. Incorrect / Incorrecta

English: Vendor support is not a relevant factor for determining the criticality classification.

Español: El soporte del proveedor no es un factor relevante para determinar la clasificación de criticidad.

D. Incorrect / Incorrecta

English: The associated threats and vulnerabilities will be evaluated only if the application is critical to the business.

Español: Las amenazas y vulnerabilidades asociadas se evaluarán únicamente si la aplicación es crítica para el negocio.

Suggested speaking script / Guion sugerido

English: I would choose A because an application is critical when the business depends on it. Its purchase or replacement price does not establish its operational importance.

Español: Elegiría la A porque una aplicación es crítica cuando el negocio depende de ella. Su precio de compra o reemplazo no determina su importancia operativa.

Question 6 / Pregunta 6

English: When conducting an audit of client-server database security, the IS auditor should be MOST concerned about the availability of:

A. system utilities.

B. application program generators.

C. systems security documentation.

D. access to stored procedures.

Español: Al realizar una auditoría de seguridad de una base de datos cliente-servidor, el auditor de SI debe preocuparse MÁS por la disponibilidad de:

A. Utilidades del sistema.

B. Generadores de programas de aplicación.

C. Documentación de seguridad de los sistemas.

D. Acceso a procedimientos almacenados.

Correct answer / Respuesta correcta: A

Explanation of every option / Justificación de cada alternativa

A. Correct / Correcta

English: System utilities may enable unauthorized changes to be made to data on the client-server database. In an audit of database security, the controls over such utilities would be the primary concern of the information systems (IS) auditor.

Español: Las utilidades del sistema pueden permitir cambios no autorizados en los datos de la base de datos cliente-servidor. En una auditoría de seguridad de bases de datos, los controles sobre esas utilidades serían la preocupación principal del auditor de SI.

B. Incorrect / Incorrecta

English: Application program generators are an intrinsic part of client-server technology, and the IS auditor would evaluate the controls over the generator's access rights to the database rather than their availability.

Español: Los generadores de programas de aplicación son una parte intrínseca de la tecnología cliente-servidor. El auditor evaluaría los controles sobre los derechos de acceso del generador a la base de datos, en lugar de su disponibilidad.

C. Incorrect / Incorrecta

English: Security documentation should be restricted to authorized security staff, but this is not a primary concern.

Español: La documentación de seguridad debe estar restringida al personal de seguridad autorizado, pero no es la preocupación principal.

D. Incorrect / Incorrecta

English: Access to stored procedures is not a primary concern.

Español: El acceso a procedimientos almacenados no es una preocupación principal.

Suggested speaking script / Guion sugerido

English: I would choose A because system utilities can provide powerful access to database data. The auditor must check controls that prevent unauthorized changes through those tools.

Español: Elegiría la A porque las utilidades del sistema pueden proporcionar acceso potente a los datos. El auditor debe revisar los controles que eviten modificaciones no autorizadas mediante esas herramientas.

Question 7 / Pregunta 7

English: When reviewing a network used for internet communications, an IS auditor will FIRST examine the:

A. validity of password change occurrences.
B. architecture of the client-server application.
C. network architecture and design.
D. firewall protection and proxy servers.

Español: Al revisar una red utilizada para comunicaciones por Internet, el auditor de SI examinará PRIMERO:

A. La validez de los cambios de contraseña realizados.
B. La arquitectura de la aplicación cliente-servidor.
C. La arquitectura y el diseño de la red.
D. La protección del firewall y los servidores proxy.

Correct answer / Respuesta correcta: C

Explanation of every option / Justificación de cada alternativa

A. Incorrect / Incorrecta

English: Reviewing the validity of password changes would be performed as part of substantive testing.

Español: La revisión de la validez de los cambios de contraseña se realizaría como parte de las pruebas sustantivas.

B. Incorrect / Incorrecta

English: Understanding the network architecture and design is the starting point for identifying the various layers of information and the access architecture across the various layers, such as client-server applications.

Español: Comprender la arquitectura y el diseño de la red es el punto de partida para identificar las distintas capas de información y la arquitectura de acceso entre ellas, como las aplicaciones cliente-servidor.

C. Correct / Correcta

English: The first step in auditing a network is to understand the network architecture and design. Understanding the network architecture and design provides an overall picture of the network and its connectivity.

Español: El primer paso al auditar una red es comprender su arquitectura y diseño. Esto proporciona una visión general de la red y de su conectividad.

D. Incorrect / Incorrecta

English: Understanding the network architecture and design is the starting point for identifying the various layers of information and the access architecture across the various layers, such as proxy servers and firewalls.

Español: Comprender la arquitectura y el diseño de la red es el punto de partida para identificar las distintas capas de información y la arquitectura de acceso entre ellas, como los servidores proxy y los firewalls.

Suggested speaking script / Guion sugerido

English: I would choose C because I need to understand how the network is organized before assessing individual controls. Its design shows the connections and access paths that need review.

Español: Elegiría la C porque necesito comprender cómo está organizada la red antes de evaluar controles específicos. Su diseño muestra las conexiones y rutas de acceso que deben revisarse.

Question 8 / Pregunta 8

English: An IS auditor should be involved in:

A. observing tests of the disaster recovery plan (DRP).
B. developing the DRP.
C. maintaining the DRP.
D. reviewing the disaster recovery requirements of supplier contracts.

Español: Un auditor de SI debe participar en:

A. La observación de las pruebas del plan de recuperación ante desastres (DRP).
B. El desarrollo del DRP.
C. El mantenimiento del DRP.
D. La revisión de los requisitos de recuperación ante desastres de los contratos con proveedores.

Correct answer / Respuesta correcta: A

Explanation of every option / Justificación de cada alternativa

A. Correct / Correcta

English: The information systems (IS) auditor should always be present when disaster recovery plans (DRP) are tested to ensure that the tested recovery procedures meet the required targets for restoration, that recovery procedures are effective and efficient, and to report on the results as appropriate.

Español: El auditor de SI debe estar siempre presente cuando se prueban los planes de recuperación ante desastres (DRP), para comprobar que los procedimientos probados cumplen los objetivos de restauración requeridos, que son eficaces y eficientes, y para informar de los resultados según corresponda.

B. Incorrect / Incorrecta

English: IS auditors may be involved in overseeing plan development, but they are unlikely to be involved in the actual development process.

Español: Los auditores de SI pueden participar en la supervisión del desarrollo del plan, pero es poco probable que participen en el proceso de elaboración propiamente dicho.

C. Incorrect / Incorrecta

English: Similarly, an audit of plan maintenance procedures may be conducted, but the IS auditor normally would not have any responsibility for the actual maintenance.

Español: Asimismo, pueden auditarse los procedimientos de mantenimiento del plan, pero normalmente el auditor de SI no tendría responsabilidad sobre su mantenimiento efectivo.

D. Incorrect / Incorrecta

English: An IS auditor may be asked to comment upon various elements of a supplier contract, but this is not always the case.

Español: Puede solicitarse a un auditor de SI que comente diversos elementos de un contrato con un proveedor, pero esto no siempre ocurre.

Suggested speaking script / Guion sugerido

English: I would choose A because the auditor should observe recovery tests and evaluate their results. Keeping an assessment role helps preserve independence from the team that develops and maintains the plan.

Español: Elegiría la A porque el auditor debe observar las pruebas de recuperación y evaluar sus resultados. Mantener un papel de evaluación ayuda a conservar su independencia del equipo que desarrolla y mantiene el plan.

Question 9 / Pregunta 9

English: Data mirroring should be implemented as a recovery strategy when:

A. recovery point objective (RPO) is low.
B. RPO is high.
C. recovery time objective (RTO) is high.
D. disaster tolerance is high.

Español: La replicación espejo de datos (data mirroring) debe implementarse como estrategia de recuperación cuando:

A. El objetivo de punto de recuperación (RPO) es bajo.
B. El RPO es alto.
C. El objetivo de tiempo de recuperación (RTO) es alto.
D. La tolerancia a desastres es alta.

Correct answer / Respuesta correcta: A

Explanation of every option / Justificación de cada alternativa

A. Correct / Correcta

English: Recovery point objective (RPO) is the earliest point in time at which it is acceptable to recover the data. In other words, RPO indicates the age of the recovered data (i.e., how long ago the data was backed up or otherwise replicated). If RPO is very low, such as minutes, it means that the organization cannot afford to lose even a few minutes of data. In such cases, data mirroring (synchronous data replication) should be used as a recovery strategy.

Español: El objetivo de punto de recuperación (RPO) es el punto más antiguo en el tiempo al que resulta aceptable recuperar los datos. En otras palabras, indica la antigüedad de los datos recuperados: cuánto tiempo ha pasado desde su respaldo o replicación. Si el RPO es muy bajo, por ejemplo, minutos, significa que la organización no puede permitirse perder ni siquiera unos pocos minutos de datos. En esos casos, debe utilizarse la replicación espejo de datos (replicación síncrona) como estrategia de recuperación.

B. Incorrect / Incorrecta

English: If RPO is high, such as hours, then other backup procedures could be used.

Español: Si el RPO es alto, por ejemplo, horas, pueden utilizarse otros procedimientos de respaldo.

C. Incorrect / Incorrecta

English: A high recovery time objective (RTO) means that the IT system may not be needed immediately after the disruption/declaration of disaster (i.e., it can be recovered later).

Español: Un objetivo de tiempo de recuperación (RTO) alto significa que el sistema de TI podría no necesitarse inmediatamente después de la interrupción o declaración de desastre; es decir, puede recuperarse más tarde.

D. Incorrect / Incorrecta

English: RTO is the time from the disruption/declaration of disaster during which the business can tolerate the nonavailability of IT facilities. If RTO is high, slower recovery strategies that bring up IT systems and facilities can be used.

Español: El RTO es el tiempo transcurrido desde la interrupción o declaración de desastre durante el cual el negocio puede tolerar que las instalaciones de TI no estén disponibles. Si el RTO es alto, pueden utilizarse estrategias más lentas para recuperar los sistemas y las instalaciones de TI.

Source note / Nota del original: Option D refers to disaster tolerance, but its explanation discusses RTO. / La opción D habla de tolerancia a desastres, pero su explicación trata del RTO. Se conserva el contenido proporcionado.

Suggested speaking script / Guion sugerido

English: I would choose A because a low RPO means the business accepts very little data loss. Synchronous mirroring keeps the recovery copy updated with minimal lag.

Español: Elegiría la A porque un RPO bajo significa que el negocio acepta perder muy pocos datos. La replicación síncrona mantiene la copia de recuperación actualizada con un desfase mínimo.

Question 10 / Pregunta 10

English: Which of the following components of a business continuity plan (BCP) is PRIMARILY the responsibility of an organization's IT department?

A. Developing the BCP
B. Selecting and approving the recovery strategies used in the BCP
C. Declaring a disaster
D. Restoring the IT systems and data after a disaster

Español: ¿Cuál de los siguientes componentes de un plan de continuidad del negocio (BCP) es responsabilidad PRINCIPAL del departamento de TI de una organización?

A. Desarrollar el BCP.
B. Seleccionar y aprobar las estrategias de recuperación utilizadas en el BCP.
C. Declarar un desastre.
D. Restaurar los sistemas de TI y los datos después de un desastre.

Correct answer / Respuesta correcta: D

Explanation of every option / Justificación de cada alternativa

A. Incorrect / Incorrecta

English: Members of the organization's senior management are primarily responsible for overseeing the development of the business continuity plan (BCP) and are accountable for the results.

Español: Los miembros de la alta dirección de la organización son los principales responsables de supervisar el desarrollo del plan de continuidad del negocio (BCP) y deben rendir cuentas por sus resultados.

B. Incorrect / Incorrecta

English: Management is also accountable for selecting and approving the strategies used for disaster recovery.

Español: La dirección también debe rendir cuentas por la selección y aprobación de las estrategias utilizadas para la recuperación ante desastres.

C. Incorrect / Incorrecta

English: IT may be involved in declaring a disaster but is not primarily responsible.

Español: TI puede participar en la declaración de un desastre, pero no es el principal responsable.

D. Correct / Correcta

English: The IT department of an organization is primarily responsible for restoring the IT systems and data after a disaster within the designated timeframes.

Español: El departamento de TI de una organización es el principal responsable de restaurar los sistemas de TI y los datos después de un desastre dentro de los plazos establecidos.

Suggested speaking script / Guion sugerido

English: I would choose D because IT is responsible for the technical recovery of systems and data. Management is responsible for directing and approving the broader business continuity decisions.

Español: Elegiría la D porque TI se encarga de la recuperación técnica de los sistemas y los datos. La dirección dirige y aprueba las decisiones generales de continuidad del negocio.